1. **¿Qué son los ataques de inyección?**
    a. Es un tipo de ataque donde un atacante ingresa información incorrecta/inválida en una aplicación web con el fin de generar un resultado o respuesta inesperada.

2. **¿Qué son los ataques de autenticación rota?**
    a. Son los ataques que explotan los mecanismos de gestión de sesiones (que pueden ser defectuosos o mal implementados) de un sistema para obtener acceso no autorizado.

3. **Identifiquen qué es lo que la mayoría de los ataques tienen en común**
    a. Casi todos nacen de errores humanos o de implementación, no de técnicas exóticas. Sucuri señala varias causas:
        - Datos de entrada que no se validan
        - Configuraciones por defecto
        - Componentes sin actualizar
        - Confianza ciega en terceros
        - Software hecho con inexperiencia o con prisa, sin requisitos de seguridad

4. **Identifiquen al menos un caso real por cada vulnerabilidad y cómo se pueden prevenir?**

Vulnerabilidad	**Caso real**	**Origen del problema**	**Mitigación**
Broken Access Control	WordPress REST API 4.7.x (2017)	Un endpoint validaba mal el parámetro id, y usuarios sin permisos podían editar posts.	Parche en WordPress 4.7.2.
Cryptographic Failures	LinkedIn (2012)	Contraseñas almacenadas con SHA-1 sin salt, fáciles de descifrar.	Argon2, bcrypt o scrypt con salt, y MFA.

Injection	TalkTalk (2015)	Páginas web antiguas vulnerables a SQL injection daban acceso a la base de datos.	Consultas parametrizadas, retiro de páginas heredadas y mínimo privilegio en la BD.
Insecure Design	Snapchat Find Friends (2013)	La función se diseñó sin límite de consultas ni control contra cuentas automatizadas.	La FTC exigió un programa integral de privacidad y seguridad. Rate limiting y modelado de abusos desde el diseño.
Security Misconfiguration	Memcached expuesto, ataque a GitHub (2018)	Los servidores memcached abiertos a Internet con UDP habilitado amplificaron el tráfico a 1.35 Tbps.	GitHub desvió su tráfico a un proveedor de mitigación DDoS (Akamai). Desactivar UDP y cerrar el puerto al exterior.
Vulnerable and Outdated Components	Equifax (2017)	Un sistema siguió sin parchear la falla de Apache Struts durante meses, pese al aviso.	Acuerdo con la FTC y mejoras de seguridad. Inventario de componentes y parches con plazos obligatorios.
Identification and Authentication Failures	23andMe (2023)	Credential stuffing con contraseñas reutilizadas, sin MFA obligatorio.	Se hizo obligatoria la verificación en dos pasos.
Software and Data Integrity Failures	SolarWinds (2020)	Los atacantes comprometieron el proceso de actualización de Orion y metieron una puerta trasera en versiones legítimas.	Proteger el pipeline de compilación, verificar integridad más allá de la firma y vigilar el tráfico saliente.
Security Logging and Monitoring Failures	Target (2013)	Entraron con credenciales de un proveedor externo y avanzaron hacia la red de datos de clientes, sin segmentación suficiente. Las alertas de FireEye se ignoraron y el bloqueo	Target anunció tarjetas con chip a inicios de 2015. Equipo que atienda alertas, bloqueo automático activo, segmentación de red y MFA para proveedores.

		automático estaba apagado.	
Server-Side Request Forgery	Capital One (2019)	Un WAF mal configurado permitió enviar solicitudes al servicio de metadatos de AWS, que entregó credenciales de un rol con permisos excesivos. Con ellas se accedió a los buckets S3.	AWS lanzó IMDSv2 en noviembre de 2019. Corregir el WAF, aplicar mínimo privilegio al rol de IAM, usar allowlist de URLs.

- Sucuri. (2024, January 2). OWASP Top Security Risks & Vulnerabilities 2021 Edition. Sucuri. https://sucuri.net/guides/owasp_top_10_2021_edition/
- BI Editorial. (2023, June 5). Target missed many warning signs leading to breach: Senate report - Business Insurance. Business Insurance. https://www.businessinsurance.com/target-missed-many-warning-signs-leading-to-breach-senate-report/
- Postal, A. (2017, April 28). Target missed chances to prevent massive data breach: Senate report. Advisen Ltd. https://www.advisenltd.com/2014/03/30/target-missed-chances-to-prevent-massive-data-breach-senate-report/
- Report says Target knew about the data breach, but did nothing. (2020, July 11). ATM Marketplace. https://www.atmmarketplace.com/articles/report-says-target-knew-about-the-data-breach-but-did-nothing/
- What We Can Learn from the Capital One Hack – Krebs on Security. (2019, August 5). https://krebsonsecurity.com/2019/08/what-we-can-learn-from-the-capital-one-hack/
- Harvey, S. (2022, December 15). Best practices for configuring your AWS perimeter. KirkpatrickPrice. https://kirkpatrickprice.com/blog/best-practices-for-configuring-your-aws-perimeter/

- Capital One Data Breach (2019): attack path, root causes, and cloud security lessons | CloudSEK. (n.d.). https://www.cloudsek.com/knowledge-base/capital-one-data-breach